

The Human Side of Cybersecurity

An Introduction to Social Engineering

August 3, 2026

When people imagine a cyberattack, they often picture lines of code moving across a dark screen while a hacker searches for a technical weakness. That kind of attack certainly exists, but many successful intrusions begin in a much more ordinary way: with a conversation. An attacker sends an email, makes a phone call, starts a text-message exchange, or walks through a door while appearing to belong there. Instead of breaking through a firewall, the attacker persuades someone to provide access.

This is the world of social engineering. In *Social Engineering: The Science of Human Hacking*, cybersecurity researcher Christopher Hadnagy defines social engineering broadly as an act that “influences a person to take an action.” That action may be harmless or helpful, but in a cybersecurity attack, it is usually something that benefits the attacker: opening a file, revealing information, transferring money, changing a password, or allowing someone into a restricted area.

Understanding social engineering is essential for anyone preparing for a career in cybersecurity because technology does not operate separately from people. Every network has users, administrators, support technicians, managers, vendors, and customers. Each person makes decisions, and every decision creates an opportunity for either security or compromise.

The Human Being in the Security System

Organizations spend large amounts of money protecting their systems. They install firewalls, endpoint protection, intrusion-detection systems, multifactor authentication, surveillance cameras, and access-control systems. These defenses can make a direct technical attack difficult. However, an attacker may not need to defeat them if someone on the inside can be persuaded to provide access.

Consider an employee who receives a message that appears to come from the company’s technical-support department. The message warns that the employee’s account will be disabled unless it is verified immediately. A link leads to a convincing copy of the organization’s login page. If the employee enters a username, password, and authentication code, the attacker may receive everything needed to access the real account.

No encryption algorithm was broken. No firewall was bypassed. The attacker created a situation in which a person made the desired decision.

This does not mean that people are foolish or that users should be blamed whenever an attack succeeds. Social engineers deliberately create situations that interfere with careful decision-making. They use urgency, fear, curiosity, helpfulness, authority, trust, and other normal human responses. The victim is often trying to do the right thing—solve a problem, help a coworker, respond to a supervisor, or protect an account. The attacker turns that good intention into a vulnerability.

Thinking Is the Attacker's Enemy

A social engineer generally wants the target to react before examining the situation closely. If a person stops to verify a request, inspect an email address, call a known phone number, or ask a supervisor for confirmation, the attack becomes much more difficult.

That is why social-engineering messages frequently create pressure. A fraudulent message may claim that an account will be closed, a package cannot be delivered, a payment is overdue, or a manager needs information immediately. The story is designed to make delay feel dangerous. When the target becomes worried about the supposed emergency, verifying the request may seem less important than responding quickly.

Attackers also take advantage of familiar expectations. A person carrying a ladder, wearing a uniform, or holding a delivery package may pass through a secured doorway because other people assume that the person belongs there. An email containing a familiar logo may be trusted because it looks like messages the recipient has seen before. A caller who knows an employee's name, department, and supervisor may sound like an insider even when that information was collected from public sources.

Hadnagy explains that social engineers may also exploit social biases involving age, occupation, status, race, or gender. Recognizing this does not mean accepting or approving those biases. It means understanding that attackers can use stereotypes and expectations to avoid suspicion. A cybersecurity professional must learn to evaluate identity through reliable verification procedures rather than appearance, confidence, clothing, job title, or social assumptions.

Pretexting: Building a Believable Story

A pretext is the role and situation an attacker creates to justify a request. The attacker may pretend to be a new employee, a technical-support specialist, a delivery driver, a police officer, a vendor, a customer, or an executive. A strong pretext explains who the attacker is, why the attacker is making contact, and why the target should cooperate.

For example, imagine that someone calls a school employee and claims to be a technician working on the student-information system. The caller says that a recent update has caused login failures and asks the employee to confirm an authentication code. The story contains several carefully chosen elements: a believable problem, a trusted role, a reasonable explanation for the call, and a request that appears connected to solving the problem.

The attacker may strengthen the story with information gathered through open-source intelligence. Staff directories, social-media posts, school calendars, photographs, job listings, and public documents can reveal names, positions, schedules, technology platforms, and relationships. Each detail makes the pretext sound more convincing.

This is one reason cybersecurity professionals must think carefully about information exposure.

A single public fact may seem harmless, but several facts combined can provide the foundation for a convincing impersonation.

Trust, Emotion, and Decision-Making

Human beings depend on trust. Without it, ordinary communication and cooperation would be nearly impossible. We accept directions from teachers, information from coworkers, help from technicians, and requests from family members because relationships give those communications meaning.

Hadnagy discusses research involving oxytocin, a hormone associated with social bonding and trust, as well as dopamine, a neurotransmitter involved in motivation and reward. The neuroscience of human behavior is complex, but the practical lesson is straightforward: feelings of trust, acceptance, pleasure, fear, or urgency can affect how people make decisions. Social engineers attempt to create the emotional conditions that make cooperation feel natural.

An attacker may act unusually friendly, share an apparent secret, offer help, or behave as though the target has already been trusted with an important responsibility. That apparent trust may encourage the target to respond in kind. In other situations, the attacker may use authority: “The superintendent needs this now,” “The security team instructed me to call,” or “Your manager has already approved the request.”

Security awareness therefore requires more than memorizing a list of suspicious phrases. Students preparing for cybersecurity careers must learn to notice when a message is attempting to control their emotional state. A useful question is not simply, “Does this look real?” but also, “How is this message trying to make me feel, and what does it want me to do before I have time to verify it?”

Four Common Social-Engineering Vectors

Hadnagy organizes malicious social engineering into four major categories. The first is **phishing**, which typically uses deceptive email messages. A phishing email may contain a malicious attachment, link to a fraudulent login page, or begin a longer conversation intended to steal information or money.

The second is **SMiShing**, or SMS phishing. These attacks arrive through text messages and may imitate banks, delivery services, government agencies, school officials, or online services. Because people often read text messages quickly and on small screens, they may not inspect links or sender information carefully.

The third is **vishing**, or voice phishing. In a vishing attack, the social engineer communicates by telephone or another voice service. Caller-ID information can be spoofed, so the name or number displayed on a phone cannot be treated as proof of identity. Skilled callers may sound calm, professional, and well informed.

The fourth category is **impersonation**. This may occur remotely or in person. An attacker might pretend to be an employee, contractor, law-enforcement officer, administrator, or service technician. The objective could be to enter a building, collect information, borrow a device, obtain credentials, or convince someone to perform an action.

These categories frequently overlap. An attacker might begin with a phishing email, follow it with a convincing phone call, and then direct the target to a fraudulent website. This is sometimes called a combination attack. Each step makes the next one appear more believable because the target experiences several pieces of the same invented story.

Defending Against Social Engineering

The most reliable defense is a culture in which verification is expected rather than treated as rude or inconvenient. Employees and students should be allowed to question unusual requests, even when those requests appear to come from an authority figure. A legitimate administrator, technician, or supervisor should respect a reasonable security procedure.

Before providing information or taking action, verify the request through a separate, trusted channel. Do not use the telephone number or link supplied in the suspicious message. Instead, locate the organization’s official contact information or communicate with the person through a method already

known to be valid. Never share passwords or authentication codes, and do not approve an unexpected multifactor-authentication request.

Physical security requires the same discipline. Identification badges, uniforms, confidence, and familiarity with technical language do not prove that someone is authorized. Visitors should follow the established check-in process, and secured doors should not be held open for unknown individuals simply because doing so feels polite.

Most importantly, suspicious interactions should be reported. One employee may recognize only a strange email, but the security team may discover that dozens of people received related messages. Reporting allows defenders to identify patterns, warn others, block malicious domains, preserve evidence, and respond before the attack spreads.

Learning to Protect People

Social engineering demonstrates that cybersecurity is not only about computers. It is also about communication, psychology, policy, ethics, and human behavior. A technically skilled security professional who ignores people will overlook one of the most important parts of the system.

Students entering cybersecurity should study social engineering for defensive and authorized educational purposes. Learning how attackers construct pretexts and manipulate trust makes it possible to recognize attacks, design better policies, conduct approved security assessments, and teach others without blaming them. The goal is not to become suspicious of every human interaction. It is to develop the habit of slowing down when a request involves access, money, credentials, sensitive information, or unusual urgency.

The strongest defenders understand both machines and people.

They know how networks communicate, but they also know how human beings communicate. They recognize that trust is necessary, emotion is powerful, and appearances can be manufactured. Most of all, they understand that the moment someone pauses to think, verify, and ask the right question, a social engineer begins to lose control of the situation.

Source note

Source

This article is an original educational adaptation based primarily on the discussion in “An Overview of Social Engineering” from the first chapter of the following book:

Hadnagy, Christopher. *Social Engineering: The Science of Human Hacking*. 2nd ed., Wiley, 2018. Kindle edition.